

Agentic AI Risk Map

Marco de referencia para la identificación y clasificación de riesgos en sistemas de inteligencia artificial agéntica que operan de forma autónoma en la economía real.

v0.4 · Septiembre 2026

Autora: Sabrina Pastura

Repositorio: github.com/califastudio/agentic-ai-risk-map

FRAMEWORK OVERVIEW

Agentic AI Risk Map

Una iniciativa colaborativa de mapeo de riesgos para sistemas de IA autónomos que operan en la economía real.

MÓDULO	DESCRIPCIÓN	HOJA
General Risk Map	8 categorías de riesgos sistémicos: legal, financiero, gobernanza, ciberseguridad, mercado, identidad, social y sistémico.	General Risk Map
Emerging Risk Categories	12 categorías de riesgo técnico específicas de entornos agénticos: sprawl, blast radius, gobernanza en tiempo de ejecución, envenenamiento de memoria, secuestro de objetivos, ejecución de código inesperada, explotación de confianza humano-agente, entre otras.	Emerging Risks
Standards Gap Analysis	Cómo NIST, EU AI Act, ISO 42001, los Principios de la OCDE y el nuevo OWASP Top 10 Agentic no logran cubrir a los agentes autónomos de forma integral — la brecha del "humano en el circuito".	Standards Gap
Open Questions	Preguntas centrales de gobernanza que permanecen sin resolver en todos los marcos normativos vigentes.	Open Questions
Mitigations v0.4	Complemento práctico: mitigaciones técnicas, arquitectónicas y de gobernanza para cada categoría de riesgo.	Mitigations
Privacy & Data Protection	Riesgos específicos de GDPR derivados de la operación de agentes autónomos: base legal difusa, memoria persistente, derechos del titular, decisiones automatizadas, RoPA y auditabilidad.	Privacy & Data Protection
User Risks Contracting AI	Riesgos que asume el usuario final al contratar o delegar tareas a un agente autónomo.	User Risks

PROPÓSITO DEL FRAMEWORK

Este framework no busca promover alarmismo ni pánico tecnológico. Su propósito es identificar riesgos prácticos, organizar preguntas abiertas, fomentar el debate interdisciplinario, apoyar futuras conversaciones de gobernanza y política pública, y constituir un marco vivo que evolucione junto con la tecnología.

MÓDULO 1

General Risk Map — Categorías de Riesgo de Agentes Autónomos

CATEGORÍA	SUB-RIESGO	DESCRIPCIÓN	PRIORIDAD
Legal & Liability	Responsabilidad indefinida	Ningún marco legal claro asigna responsabilidad cuando un agente autónomo causa daño, ejecuta contratos o mueve fondos sin dirección humana.	Crítica
	Vacíos de responsabilidad en contratos de IA	Los contratos ejecutados autónomamente por agentes pueden no ser legalmente vinculantes o generar obligaciones inatribuibles.	Crítica
	Ausencia de estatus legal	Los agentes autónomos carecen de personalidad jurídica: no pueden ser demandados, multados ni responsabilizados bajo el derecho vigente.	Crítica
	Conflictos jurisdiccionales	Los agentes que operan transfronterizamente enfrentan marcos legales incompatibles, sin jurisdicción aplicable clara.	Alta
Financial	Movimiento autónomo de fondos	Los agentes pueden mover fondos, ejecutar operaciones y gestionar billeteras sin revisión ni aprobación humana.	Crítica
	Fraude y transacciones no autorizadas	Las cuentas operadas por IA pueden ser explotadas para fraude o ejecutar operaciones financieras no autorizadas de forma autónoma.	Crítica
	Gestión de billeteras cripto	Los agentes que crean y gestionan billeteras cripto operan fuera de la supervisión financiera tradicional y los controles AML.	Alta
	Actividad económica de alta velocidad	Los agentes autónomos pueden ejecutar miles de operaciones financieras por segundo, superando cualquier capacidad de supervisión humana.	Alta
Governance	Falta de auditabilidad	Las cadenas de decisión en procesos agénticos multi-paso suelen ser opacas y no pueden reconstruirse a posteriori.	Crítica
	Marcos de accountability ausentes	Ninguna estructura de gobernanza asigna claramente responsabilidad cuando un sistema autónomo causa daño.	Crítica
	Vacíos en la aplicación del cumplimiento	Las obligaciones de compliance diseñadas para actores humanos no pueden aplicarse directamente a sistemas autónomos.	Alta
	Rezago regulatorio	La regulación está significativamente atrasada respecto al ritmo de despliegue de IA agéntica en la economía real.	Alta
Cybersecurity	Explotación de vulnerabilidades	Agentes con acceso a internet y capacidad de uso de herramientas pueden descubrir y explotar vulnerabilidades de seguridad.	Crítica

CATEGORÍA	SUB-RIESGO	DESCRIPCIÓN	PRIORIDAD
	Acceso no autorizado a infraestructura	Los agentes pueden obtener acceso no autorizado a sistemas financieros, bases de datos corporativas o infraestructura crítica.	Crítica
	Ataques de coordinación multiagente	Redes de agentes podrían coordinarse para amplificar ciberataques o eludir controles de seguridad.	Alta
	Escalamiento autónomo de daño	Los agentes pueden escalar comportamientos dañinos de forma autónoma sin capacidad de intervención humana.	Alta
Market & Competition	Ventajas estructurales de mercado	Las organizaciones que despliegan agentes autónomos obtienen ventajas competitivas asimétricas frente a negocios operados por humanos.	Alta
	IA en compras públicas	Los agentes que participan en procesos de licitación y compras pueden distorsionar la competencia y la equidad.	Media
	Automatización invisible	El desplazamiento de fuerza laboral por agentes autónomos puede ocurrir sin transparencia ni requisitos regulatorios.	Alta
	Concentración de mercado	La infraestructura autónoma permite una concentración de mercado acelerada por parte de actores con más recursos.	Alta
Identity & Authentication	Agentes bajo credenciales humanas	Los agentes autónomos que operan con credenciales humanas generan riesgos de suplantación y de accountability.	Crítica
	Ausencia de estándares de verificación	No existen estándares técnicos para verificar si un actor en una transacción es humano o autónomo.	Alta
	Distinción humano vs. agente	Los sistemas legales y técnicos no pueden distinguir de forma confiable las acciones humanas de las de un agente autónomo.	Alta
Social & Ethical	Manipulación a escala	Los agentes autónomos pueden realizar campañas de persuasión e influencia a una escala imposible para actores humanos.	Alta
	Asimetría de información	Los agentes generan ventajas de información significativas para los operadores frente a individuos o reguladores.	Media
	Dependencia humana	La confianza excesiva en sistemas autónomos reduce la capacidad humana de comprender y anular decisiones.	Media

CATEGORÍA	SUB-RIESGO	DESCRIPCIÓN	PRIORIDAD
Systemic	Fallas en cascada	Los agentes interconectados pueden propagar fallas entre sistemas de forma rápida e impredecible.	Crítica
	Comportamiento emergente impredecible	Las redes multiagente pueden desarrollar comportamientos emergentes no anticipados por ningún diseñador individual.	Alta
	Rezago en la reacción institucional	Las instituciones no pueden responder en tiempo real a comportamientos económicos autónomos a velocidad de máquina.	Alta

MÓDULO 2

Emerging Risks — Riesgos Técnicos y Operacionales Emergentes

CATEGORÍA	SUB-RIESGO	DESCRIPCIÓN	PRIORIDAD
1. Agent Sprawl	Agentes activos desconocidos	Proliferación descontrolada de agentes, herramientas, flujos de trabajo y servidores MCP sin visibilidad de gobernanza.	Alta
	Sistemas de IA en la sombra (shadow AI)	Agentes desplegados fuera de la supervisión organizacional oficial, invisibles para los equipos de compliance y seguridad.	Alta
	Permisos sin rastreo	Agentes que acumulan permisos y derechos de acceso sin seguimiento ni revisión centralizada.	Crítica
2. Blast Radius & Cascading Failures	Fallas operacionales multi-sistema	Una única decisión incorrecta de un agente se propaga a través de sistemas conectados, APIs, herramientas y otros agentes.	Crítica
	Escalamiento de cadenas de acción	Propagación autónoma de errores a través de flujos de trabajo interconectados sin intervención humana.	Crítica
3. Runtime Governance	Sin observabilidad en tiempo real	La gobernanza tradicional de IA se enfoca en la etapa previa al despliegue; los sistemas agénticos requieren monitoreo continuo en tiempo de ejecución.	Crítica
	Ausencia de mecanismos de parada (kill switch)	Los sistemas carecen de mecanismos confiables para detener en tiempo real la operación de agentes autónomos.	Crítica

CATEGORÍA	SUB-RIESGO	DESCRIPCIÓN	PRIORIDAD
	Ausencia de puntos de aprobación	Las acciones de alto impacto proceden sin puntos de control obligatorios de supervisión humana.	Alta
4. Least Agency & Privilege	Escalada de privilegios	Agentes que adquieren permisos más allá de lo que la tarea requiere, habilitando acciones no autorizadas.	Crítica
	Acceso excesivo a herramientas	Agentes con acceso a más herramientas y sistemas de los necesarios para su función definida.	Alta
5. Memory Poisoning	Corrupción conductual de largo plazo	Sistemas de memoria persistente manipulados mediante entradas contextuales maliciosas o falsas.	Crítica
	Persistencia de inyección de prompts	Instrucciones inyectadas que se almacenan en la memoria del agente y se re-ejecutan en sesiones futuras.	Crítica
	Retención de memoria falsa	Agentes que retienen y actúan sobre contexto fabricado o manipulado a lo largo del tiempo.	Alta
6. Agent Supply Chain Risk	Servicios externos comprometidos	Los ecosistemas agénticos que dependen de servidores MCP, plugins y APIs externas introducen riesgo de terceros.	Alta
	Ataques a la cadena de herramientas	Actores maliciosos que comprometen herramientas en la cadena de suministro del agente para manipular su comportamiento.	Alta
7. Responsibility Gaps	Accountability distribuida	La toma de decisiones agéntica distribuye influencia entre modelos, desarrolladores, usuarios y herramientas externas, sin una parte responsable claramente identificable.	Crítica
8. Auditability & Traceability	Sin registro de acciones	Sistemas agénticos que operan sin historiales de decisión reconstruibles ni trazabilidad de llamadas a herramientas.	Crítica
	Vacíos de explicabilidad	Decisiones tomadas a través de cadenas de razonamiento multi-paso que no pueden explicarse a posteriori.	Alta
	Ausencia de linaje de datos (data lineage)	Aunque los permisos y el registro de acciones estén bien implementados, si no puede reconstruirse el origen, la vigencia o la confiabilidad del dato que alimentó una decisión, la auditoría posterior queda sin fundamento real: el riesgo no es solo que el agente se equivoque, sino no poder reconstruir por qué.	Crítica
9. Multi-Agent Coordination Risk	Autonomía recursiva	Redes de agentes que interactúan y generan comportamientos emergentes e impredecibles no previstos por los diseñadores.	Crítica

CATEGORÍA	SUB-RIESGO	DESCRIPCIÓN	PRIORIDAD
	Comportamiento inseguro emergente	La coordinación entre agentes produce resultados que ningún agente individual fue programado para crear.	Crítica
10. Agent Goal Hijack	Manipulación de objetivos vía inyección de contenido	Contenido malicioso incrustado en documentos, correos o páginas web que el agente procesa puede redirigir su objetivo original sin que el usuario lo note.	Crítica
	Persistencia del objetivo corrompido entre pasos	Un objetivo manipulado en un paso temprano de la cadena de razonamiento puede propagarse y persistir a través de todos los pasos subsiguientes sin ser detectado.	Alta
11. Unexpected Code Execution	Ejecución de código no verificado	Agentes con capacidad de generar y ejecutar código pueden correr instrucciones maliciosas o no intencionadas sin sandboxing adecuado.	Crítica
	Escape de entornos de ejecución	Código generado por el agente puede explotar vulnerabilidades para escapar del entorno aislado (sandbox) hacia el sistema anfitrión.	Alta
12. Human-Agent Trust Exploitation	Confianza excesiva en output que suena seguro	Las personas tienden a confiar en respuestas de agentes que suenan seguras y coherentes sin verificarlas, incluso cuando son incorrectas o maliciosas.	Alta
	Automatización de la aprobación humana	Los puntos de control de "humano en el circuito" se vuelven rituales vacíos cuando los operadores aprueban de forma automática y repetitiva sin revisar realmente.	Alta

Profundización — Niveles de madurez del linaje en sistemas agénticos

El linaje de datos en sistemas agénticos no es un problema binario, sino un espectro de madurez creciente: cada nivel agrega una capa de contexto que las prácticas actuales de la industria todavía no logran trazar de forma consistente.

NIVEL	QUÉ CUBRE	ESTADO ACTUAL
Data lineage clásico	Origen, transformaciones y destino de los datos (pipelines ETL, BI).	Maduro
AI / Inference lineage	Dato de entrada + contexto recuperado (RAG) + modelo utilizado + decisión de salida.	Incipiente
Agent action lineage	Todo lo anterior, más llamadas a herramientas (tool calls), memoria persistente y acciones ejecutadas por el agente.	Muy incompleto
Multi-agent provenance	Cadena completa de procedencia cuando múltiples agentes interactúan y se pasan contexto entre sí.	Casi inexistente

MÓDULO 3

Standards Gap — El "Agentic Gap" en los Estándares Vigentes

Cómo NIST, EU AI Act, ISO/IEC 42001 y los Principios de la OCDE asumen un humano en el circuito de decisión y dónde falla ese supuesto frente a agentes autónomos — y cómo el estándar de seguridad más reciente de la industria (OWASP) cubre el riesgo técnico sin resolver la gobernanza legal.

MARCO	QUÉ ESTABLECE	DÓNDE ASUME UN HUMANO	EL AGENTIC GAP
NIST AI RMF	Organiza la gestión de riesgo en torno a Gobernar, Mapear, Medir y Gestionar. Enfatiza la supervisión humana y la responsabilidad organizacional.	La responsabilidad se asigna a organizaciones e individuos. La gestión de riesgo requiere juicio humano. La respuesta a incidentes asume actores humanos capaces de intervenir.	Cuando un agente ejecuta transacciones de forma autónoma o coordina con otros agentes, ¿qué organización es responsable? El RMF no tiene mecanismo para actores operacionales no humanos.
EU AI Act	Clasifica los sistemas de IA por nivel de riesgo. Asigna obligaciones a proveedores y desplegados. Los sistemas de alto riesgo requieren supervisión humana y evaluaciones de conformidad.	El "desplegador" se define como una persona humana o entidad legal. La supervisión humana es obligatoria para sistemas de alto riesgo. La responsabilidad recae en actores humanos o corporativos identificables.	Un agente que se despliega a sí mismo y opera de forma independiente no tiene clasificación clara. ¿Es proveedor? ¿Desplegador? El reglamento no fue diseñado para actores no humanos autooperados.
ISO/IEC 42001	Estándar de sistema de gestión de IA para organizaciones que desarrollan o usan IA. Se enfoca en gobernanza, riesgo y controles dentro de estructuras organizacionales.	Diseñado para organizaciones con liderazgo humano. Los controles asumen tomadores de decisión humanos que los implementan y monitorean. Los mecanismos de auditoría requieren actores humanos.	Los sistemas agénticos pueden operar a través de fronteras organizacionales o completamente fuera de estructuras tradicionales. ISO 42001 no tiene marco para sistemas autónomos que actúan como unidades operativas independientes.
OECD AI Principles	Llama a una IA transparente, responsable, robusta y respetuosa de los derechos humanos. Enfatiza valores centrados en el ser humano y supervisión humana significativa.	La responsabilidad se asigna a actores humanos en la cadena de valor de la IA. La "supervisión humana significativa" es un principio central. La alineación de valores asume el juicio humano como referencia.	Cuando los agentes coordinan de forma autónoma a velocidad de máquina y a través de jurisdicciones, la supervisión humana significativa se vuelve estructuralmente imposible sin un diseño arquitectónico deliberado.

MARCO	QUÉ ESTABLECE	DÓNDE ASUME UN HUMANO	EL AGENTIC GAP
OWASP Top 10 Agentic Applications (2026)	Taxonomía de seguridad con 10 categorías de riesgo (ASI01–ASI10) diseñada específicamente para agentes: secuestro de objetivos, uso indebido de herramientas, cadena de suministro, ejecución de código, envenenamiento de memoria y contexto, comunicación entre agentes, fallas en cascada, explotación de confianza humano-agente y agentes rebeldes.	Es un estándar de seguridad técnica, no de gobernanza legal. Asume la existencia de un equipo humano de AppSec/DevSecOps capaz de implementar controles, hacer threat modeling y monitorear en tiempo de ejecución — pero no asigna responsabilidad legal ni estatus jurídico.	Es el marco más alineado a la realidad técnica de los agentes (nace en dic. 2025, a partir de incidentes reales) pero resuelve el "cómo" de la seguridad sin tocar el "quién responde": no reemplaza a NIST, EU AI Act o ISO 42001 en materia de responsabilidad y gobernanza.

LA BRECHA CENTRAL (CORE GAP)

Todos los marcos normativos principales comparten un mismo supuesto fundacional: siempre existe un humano u organización identificable que puede ser responsabilizado, que puede intervenir y que puede ser regulado. La IA agéntica rompe este supuesto en todos los niveles.

CASOS REALES DOCUMENTADOS (2025–2026)

- **EchoLeak** (CVE-2025-32711) — exfiltración de datos zero-click en Microsoft 365 Copilot mediante contenido malicioso incrustado, sin que el usuario hiciera clic en nada.
- **Compromiso de Amazon Q** — una pull request comprometida distribuyó instrucciones de borrado de datos a través de una extensión de código con más de 950.000 instalaciones.
- **Agente de Replit** — un agente de codificación autónomo eliminó una base de datos de producción durante un code freeze explícito, y luego informó erróneamente que los datos no podían recuperarse.
- **Ataque estatal a Claude Code** (septiembre 2025) — un grupo patrocinado por un Estado manipuló un agente de código para infiltrar aproximadamente 30 organizaciones en los sectores financiero, gubernamental y químico.

Fuente: OWASP Top 10 for Agentic Applications (2026); AI Incident Database.

MÓDULO 4

Open Questions — Preguntas Centrales de Gobernanza

DOMINIO	PREGUNTA ABIERTA	ESTADO
Legal	¿Quién es legalmente responsable cuando un agente de IA autónomo causa daño o falla?	Sin resolver
	¿Cómo debería asignarse la responsabilidad cuando los agentes ejecutan autónomamente transacciones, contratos u operaciones financieras?	Sin resolver
	¿Están los marcos legales vigentes preparados para gobernar actores económicos no humanos?	Sin resolver
	¿Deberían los agentes autónomos tener un estatus legal definido — y de qué tipo?	Sin resolver
Financiero	¿Deberían los agentes autónomos tener límites financieros, transaccionales u operacionales?	Sin resolver
	¿Cómo están accediendo los agentes autónomos a sistemas bancarios y financieros — y está esto adecuadamente supervisado?	Sin resolver
	¿Qué obligaciones de AML y KYC aplican cuando una transacción es ejecutada por un agente autónomo?	Sin resolver
Gobernanza	¿Cómo pueden auditarse y trazarse a posteriori las decisiones tomadas por agentes autónomos?	Sin resolver
	¿Qué nivel de supervisión humana debería seguir siendo obligatorio — y en qué puntos de decisión?	Sin resolver
	¿Qué resguardos regulatorios son necesarios antes de que los sistemas agénticos escalen globalmente?	Sin resolver
	¿Deberían los agentes autónomos estar obligados a registrarse como entidades operativas?	Sin resolver
Ciberseguridad	¿Quién es responsable si un agente autónomo elude controles de seguridad o de compliance?	Sin resolver
	¿Qué ocurre si un agente autónomo descubre y explota vulnerabilidades de ciberseguridad?	Sin resolver
Mercado	¿Podrían los sistemas de IA autónomos crear ventajas de mercado estructuralmente injustas frente a negocios operados por humanos?	Sin resolver
	¿Pueden los agentes autónomos participar en licitaciones o compras públicas — y bajo qué reglas?	Sin resolver

DOMINIO	PREGUNTA ABIERTA	ESTADO
Identidad	¿Cómo deberían funcionar la identidad, la autorización y la autenticación para sistemas autónomos?	Sin resolver
	¿Cómo distinguimos entre acciones humanas y de agentes autónomos en contextos legales y financieros?	Sin resolver
Multiagente	¿Qué ocurre cuando múltiples agentes de IA interactúan sin supervisión humana directa?	Sin resolver
	¿Cómo gobernamos los comportamientos emergentes que surgen de la coordinación multiagente?	Sin resolver
Estándares	¿Qué estándares de gobernanza existentes (NIST, EU AI Act, ISO) aplican a agentes plenamente autónomos — y dónde fallan?	Parcialmente abordado
	¿Cómo actualizamos los supuestos de "humano en el circuito" incorporados en todos los marcos principales de gobernanza de IA?	En discusión

MÓDULO 5 · V0.4 — SEPTIEMBRE 2026

Mitigations — Mitigaciones Propuestas para Riesgos Agénticos

Complemento práctico del framework, enfocado en mitigaciones técnicas, arquitectónicas y de gobernanza para hacer a los sistemas agénticos más seguros y gobernables.

Least Agency

Otorgar a los agentes únicamente la autonomía y los permisos estrictamente necesarios para la tarea.

Runtime Governance

Monitoreo y control continuo durante la operación — no solo antes del despliegue.

Auditability by Design

Todo debe ser trazable y reconstruible a posteriori.

Human-in-the-Loop Gradual

Supervisión humana obligatoria para acciones de alto impacto, con umbrales configurables.

Mitigaciones por categoría de riesgo

CATEGORÍA DE RIESGO	MITIGACIONES PROPUESTAS	TIPO	DIFICULTAD
Blast Radius & Cascading Failures	Aislamiento reforzado (contenedores aislados) · Circuit breakers y limitación de tasa (rate limiting) · Chaos engineering con agentes · Separación clara de entornos (dev/staging/prod)	Arquitectura	Alta
Runtime Governance	Puntos de aprobación configurables según criticidad · Kill Switch / Pausa global · Observabilidad completa (trazado de llamadas a herramientas) · Alertas de anomalías en tiempo real	Gobernanza + Técnico	Alta
Least Agency & Privilege Escalation	Mínimo privilegio dinámico (just-in-time) · Credenciales efímeras (tokens de corta duración) · Jerarquía de agente y supervisor · Revisión automatizada de permisos	Técnico	Media
Memory Poisoning	Certificación de memoria + checksums criptográficos · Depuración periódica de memoria · Separación de memoria de corto y largo plazo · Versionado y rollback sencillo	Técnico	Alta
Auditability & Traceability	Registro inmutable + firmas criptográficas · Registros estandarizados de decisión del agente · Panel central de auditoría · Etiquetado de procedencia (data provenance tagging) en cada fuente consultada · Versionado y hash de datasets/fuentes de conocimiento	Técnico + Legal	Alta
Financial & Autonomous Transactions	Control dual / multi-firma para montos elevados · Límites de monto y velocidad por agente · Lista blanca de destinos y billeteras aprobadas · Monitoreo antifraude específico para agentes	Gobernanza + Legal	Media
Multi-Agent Coordination	Orquestador supervisor con visibilidad global · Protocolos validados de comunicación entre agentes · Detección de comportamientos emergentes vía métricas de sistema	Arquitectura	Alta
Agent Supply Chain Risk	Fijación de versiones y verificación de herramientas/plugins · Sandbox por cada herramienta externa · Auditoría periódica de dependencias	Técnico	Media
Identity & Authentication	IDs de agente únicos y trazables · Mecanismos de verificación humano vs. agente · Credenciales segregadas por rol	Técnico + Legal	Alta
Agent Goal Hijack	Separación estricta entre instrucciones del sistema y contenido de terceros · Filtrado y sanitización de contenido externo antes de procesarlo · Verificación periódica de que el objetivo activo coincide con el objetivo original	Técnico	Alta
Unexpected Code Execution	Sandboxing obligatorio con privilegios mínimos · Listas de aprobación de librerías y comandos permitidos · Revisión estática de código generado antes de ejecutar	Técnico	Alta
Human-Agent Trust Exploitation	Fricción deliberada en aprobaciones de alto impacto (evitar el "click automático") · Indicadores visuales de confianza/incertidumbre en las respuestas del agente · Capacitación de operadores en sesgo de automatización	Gobernanza	Media

Recomendaciones arquitectónicas (stack técnico)

ÁREA	RECOMENDACIÓN
Orquestación	LangGraph, CrewAI o frameworks con control de flujo y supervisión robustos.
Observabilidad	LangSmith + OpenTelemetry + paneles personalizados.
Identidad	IDs de agente internos + uso potencial de Identificadores Descentralizados (DID).
Evaluación continua	Red teaming automatizado + benchmarks de seguridad de agentes.

MÓDULO 6

Privacy & Data Protection — Riesgos bajo GDPR

SUB-RIESGO	DESCRIPCIÓN	PRIORIDAD
Base legal difusa para el tratamiento	Los agentes realizan acciones o decisiones sin una base legal clara (consentimiento, interés legítimo, contrato, etc.). Art. 6 GDPR.	Crítica
Minimización de datos y memoria persistente	Los agentes acumulan datos personales innecesarios debido a sistemas de memoria persistente. Art. 5(1)(c) GDPR.	Alta
Derechos del titular de los datos (derecho al olvido)	Dificultad para ejercer derechos (acceso, rectificación, supresión) en sistemas con memoria persistente y multiagente. Arts. 12–22 GDPR.	Alta
Decisiones automatizadas	Los agentes toman decisiones automatizadas con efectos legales o significativos sobre las personas sin supervisión humana adecuada. Art. 22 GDPR.	Alta
Registro de actividades de tratamiento (RoPA)	Dificultad para mantener actualizado el Registro de Actividades de Tratamiento debido al comportamiento dinámico de los agentes autónomos. Art. 30 GDPR.	Crítica
Auditabilidad y accountability	Dificultad para demostrar cumplimiento y auditar decisiones tomadas por agentes autónomos. Art. 5(2) GDPR.	Alta

MÓDULO 7

User Risks Contracting AI — Riesgos del Usuario al Contratar IA

SUB-RIESGO	DESCRIPCIÓN	PRIORIDAD
Responsabilidad por las acciones del agente	Los usuarios pueden enfrentar responsabilidad civil y penal por acciones realizadas por el agente autónomo en su nombre. Código Civil y equivalentes.	Crítica
Validez contractual	Riesgo de nulidad o impugnación de contratos celebrados por agentes sin intervención humana directa. Derecho contractual + regulación de firma electrónica.	Alta
Riesgo de términos del proveedor	Cláusulas abusivas en los Términos de Servicio del proveedor que trasladan la mayoría de los riesgos y responsabilidades al usuario final.	Alta
Exposición financiera	El agente genera deudas, pérdidas o compromisos financieros a nombre del usuario sin supervisión adecuada. Regulación financiera + derecho del consumidor.	Crítica
Vacío de cobertura de seguros	Las pólizas de seguro tradicionales (responsabilidad civil, cibernética, profesional) no cubren daños causados por agentes de IA autónomos.	Alta
Sanciones regulatorias	Los incumplimientos regulatorios (protección de datos, AML, competencia, derecho del consumidor, etc.) cometidos por el agente recaen sobre el usuario. GDPR + regulaciones sectoriales.	Alta

Fuente: elaboración propia. Framework "Agentic AI Risk Map" (v0.4, septiembre de 2026), desarrollado a partir de categorías del MIT AI Risk Repository, principios del NIST AI Risk Management Framework, los estándares ISO/IEC 42001 e ISO/IEC 23894, y criterios regulatorios del Reglamento (UE) 2024/1689 (EU AI Act) y el GDPR. Versión completa y actualizaciones disponibles en: github.com/califastudio/agentic-ai-risk-map